

CVE-2026-46333

Linux Kernel ptrace Local Privilege Escalation & Credential Disclosure (ssh-keysign-pwn)

Vulnerability Intelligence Report | Published: 28 May 2026 | TLP: AMBER

AI-ASSISTED REPORT — IMPORTANT DISCLOSURE

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All content, findings, detection rules, and recommendations must be independently reviewed and validated by a qualified security professional before being acted upon or implemented in any environment.

Currency: Information is based on publicly available sources at the time of generation. Verify all details against the latest vendor advisories, NVD, and CISA guidance before relying on this document.

1. Executive Summary

CVE-2026-46333, publicly known as "ssh-keysign-pwn," is a logic flaw in the Linux kernel ptrace access-check path discovered and responsibly disclosed by Qualys on 20 May 2026. An unprivileged local user can exploit a narrow race condition during the exit of a privileged SUID process to steal its open file descriptors — including SSH host private keys and the `/etc/shadow` password file — and in several configurations achieve full root code execution. The vulnerability has existed in mainline Linux since November 2016 (v4.10-rc1), meaning the historical exposure spans nine years of enterprise, cloud, and container fleets.

The business impact is severe for any organisation relying on shared Linux infrastructure, SSH-based authentication, or multi-tenant Linux hosting. Successful exploitation allows an attacker with shell access — including a low-privilege container breakout or a compromised application account — to escalate to root, dump SSH host keys enabling persistent man-in-the-middle of encrypted sessions, and exfiltrate `/etc/shadow` hashes for offline cracking. Qualys has released four working public exploits targeting `chage`, `ssh-keysign`, `pkexec`, and `accounts-daemon`, making exploitation accessible to non-expert threat actors.

Organisations should apply vendor kernel updates as an emergency priority. Where immediate patching is not possible, setting `kernel.yama.ptrace_scope` to 2 removes the exploitation vector entirely at the cost of disabling user-space debuggers. Detection teams should deploy `auditd` and KQL rules to identify `pidfd_getfd` syscall abuse and unexpected SSH key file access within 48 hours.

Attribute	Detail
CVE ID	CVE-2026-46333
Disclosure Date	20 May 2026
Vulnerability Type	Local Privilege Escalation / Information Disclosure
Affected Component	Linux kernel <code>__ptrace_may_access()</code> via <code>pidfd_getfd()</code>
CVSSv3 Score	7.8 — HIGH
Attack Vector	Local (AV:L)
Attack Complexity	High (AC:H) — race condition required
Privileges Required	Low (PR:L) — unprivileged shell account
User Interaction	None (UI:N)
Scope	Unchanged (S:U)
Exploit Status	Public PoC — Qualys released 4 working exploits (<code>chage</code> , <code>ssh-keysign</code> , <code>pkexec</code> , <code>accounts-daemon</code>)

Zero-Day	No — patched upstream commit 31e62c2ebbfd
Patch Available	Yes — vendor kernel updates available across all major distributions

2. Vulnerability Details

2.1 Root Cause

The vulnerability is a race condition and logic flaw in the Linux kernel `__ptrace_may_access()` function. During the exit sequence of a privileged SUID process (such as `ssh-keysign`, `pkexec`, or `chage`), the kernel releases the task memory descriptor (`mm_struct`) before closing its file descriptor table. This creates a narrow window where the task `mm` pointer is `NULL`.

The `__ptrace_may_access()` function uses the dumpability check (`get_dumpable()`) as a safety gate — a process is only ptraced if it is dumpable (non-SUID or explicitly configured). However, when `mm` is `NULL`, `get_dumpable()` returns 0 by default and the safety gate is bypassed incorrectly. An unprivileged attacker process can leverage `pidfd_getfd(2)` — introduced in Linux 5.6 in 2020 — during this window to clone file descriptors from the exiting privileged process, giving it direct read access to any file that process had open, including `/etc/ssh/ssh_host_*` and `/etc/shadow`.

The upstream fix (commit 31e62c2ebbfd: "ptrace: slightly saner `get_dumpable()` logic") ensures that when `mm` is `NULL` the dumpable check correctly defaults to non-dumpable, closing the race window.

2.2 Affected Products

Distribution / Product	Affected Versions	Status
Linux Kernel (mainline)	v5.6 through current (all kernels with <code>pidfd_getfd</code>)	Patched — upstream commit 31e62c2ebbfd
Red Hat Enterprise Linux 6 & 10	Affected kernel packages	Patch available via RHSA
Ubuntu (all LTS releases)	Kernels ≥ 5.6	Patch available via USN advisory
Azure Linux 3.0	Affected kernel packages	Patch available via MSFT advisory
CloudLinux	Kernels ≥ 5.6	Patch available — KernelCare live-patch option
Debian / Kali / Arch Linux	Kernels ≥ 5.6	Upstream patch applicable
Container hosts (Docker / Kubernetes)	Host kernel ≥ 5.6 without patch	Patch host kernel — seccomp mitigation available
Kernels < 5.6 (no <code>pidfd_getfd</code>)	Not exploitable via this technique	Not affected by this specific PoC

2.3 Attack Scenarios

Scenario 1 — SSH Host Key Theft: An attacker with a low-privilege shell account on a multi-user Linux server races the exit of `ssh-keysign` using `pidfd_getfd()` to clone the file descriptor pointing to `/etc/ssh/ssh_host_ed25519_key`. The attacker exfiltrates the key, enabling persistent MitM decryption of

all SSH sessions to that host and silent authentication to downstream systems without triggering certificate warnings. This is the highest-impact variant on internet-facing infrastructure.

Scenario 2 — /etc/shadow Extraction and Root Escalation: An attacker targeting a default RHEL or Ubuntu system races the chage binary exit window to acquire a descriptor to /etc/shadow. The attacker reads all password hashes and submits them to an offline cracking pipeline. Root credentials recovered this way provide direct escalation and persistence. The Qualys PoC demonstrates this reliably on default installs.

Scenario 3 — Container Breakout Chain: A compromised application container with an unpatched host kernel exploits CVE-2026-46333 against a SUID binary accessible from the container namespace. This breaks container isolation, achieves root on the host node, and provides access to all tenant data on that Kubernetes worker. Combined with cloud IMDS credential theft (T1552.005), this becomes a full cloud account compromise chain.

2.4 CVSS v3.1 Breakdown

Metric	Value	Rationale
Attack Vector	Local (L)	Requires local shell access — no remote exploitation without prior initial access
Attack Complexity	High (H)	Race condition window must be won — reliable but requires repeated attempts
Privileges Required	Low (L)	Any unprivileged shell account is sufficient; no special group membership
User Interaction	None (N)	No victim interaction required once attacker has local shell
Scope	Unchanged (U)	Exploit operates within the existing kernel privilege context
Confidentiality	High (H)	SSH host keys and /etc/shadow fully readable — complete credential compromise
Integrity	High (H)	Root code execution achievable via credential abuse post-theft
Availability	High (H)	Root access enables full system disruption or ransomware deployment

3. Threat Landscape & Context

CVE-2026-46333 is an unusually high-quality local privilege escalation. The disclosure was accompanied by four working Qualys exploits and a detailed technical writeup, making it immediately accessible to script-level threat actors. The affected code has been present since Linux 4.10 (2016) and the exploitable `pidfd_getfd` attack primitive since 5.6 (2020), meaning unpatched systems carry six years of potential retrospective exposure.

The exploitation technique — racing a SUID process exit using `pidfd_getfd` — is novel, does not require kernel memory corruption or heap spraying, and is highly reliable across kernel versions and distributions. The technique may inspire follow-on research identifying similar race windows in other process-exit paths.

Threat actor interest is high: local privilege escalation vulnerabilities are a critical link in post-initial-access kill chains for ransomware groups, APT operators targeting Linux server infrastructure, and cloud-hosted cryptomining campaigns. This vulnerability is particularly dangerous in shared hosting environments, CI/CD pipelines, container orchestration nodes, and any environment where untrusted code runs under non-root accounts.

Related vulnerabilities in the Linux kernel privilege escalation space include CVE-2019-13272 (PTRACE_TRACEME), CVE-2021-4034 (PwnKit — also targeting `pkexec`), and Dirty Pipe CVE-2022-0847. This class has a consistent track record of rapid operational weaponisation within days of public PoC release.

4. Mitigation

4.1 Apply the Vendor Kernel Patch (Primary Remediation)

The upstream fix is commit `31e62c2ebbfd`. All major distributions have released or are releasing kernel updates. Apply via your distribution package manager and reboot:

```
# RHEL / CentOS Stream / Fedora
sudo dnf update kernel && sudo reboot

# Ubuntu / Debian
sudo apt-get update && sudo apt-get upgrade linux-image-generic && sudo
reboot

# Azure Linux 3.0
sudo tdnf update kernel && sudo reboot
```

CloudLinux KernelCare users can apply the live patch without rebooting. Verify the running kernel includes the fix by checking the kernel version against your distribution security advisory.

4.2 Interim Workaround — Restrict ptrace Scope

If immediate kernel patching is not possible, restrict `ptrace` to prevent unprivileged cross-process access. Setting `ptrace_scope` to 2 restricts `pidfd_getfd` abuse entirely:

```
# Apply immediately (no reboot required)
sudo sysctl -w kernel.yama.ptrace_scope=2

# Persist across reboots
echo "kernel.yama.ptrace_scope = 2" | sudo tee /etc/sysctl.d/99-ptrace-
scope.conf
sudo sysctl -p /etc/sysctl.d/99-ptrace-scope.conf
```

Warning: `ptrace_scope=2` breaks user-space debuggers (`gdb`, `strace`) unless run with `CAP_SYS_PTRACE`. Test in a non-production environment first. `Scope=1` (parent-process-only restriction) is a partial mitigation for some scenarios.

4.3 Container Workload Controls

Apply a seccomp profile that denies the `pidfd_getfd` syscall (number 438 on `x86_64`) for untrusted container workloads. First audit all SUID binaries:

```
find / -perm -4000 -type f 2>/dev/null
```

Remove SUID bits from binaries where not operationally required. For containers, enforce seccomp via Kubernetes SecurityContext or Docker `--security-opt`:

```
# seccomp profile fragment - deny pidfd_getfd
{ "defaultAction": "SCMP_ACT_ALLOW",
  "syscalls": [{ "names": ["pidfd_getfd"], "action": "SCMP_ACT_ERRNO" }] }
```

4.4 Principle of Least Privilege

Restrict shell access on shared Linux systems to accounts that genuinely require it. Enforce SSH key-based authentication only (disable password authentication in `sshd_config`). Segment shell-accessible systems behind jump hosts and implement session recording for audit trails.

5. Detection

5.1 Endpoint Behavioural Indicators

Key behavioural indicators for CVE-2026-46333 exploitation include: invocation of `pidfd_getfd` (syscall 438) from user-space processes without `CAP_SYS_PTRACE`; rapid repeated `fork/exec` of SUID binaries (`ssh-keysign`, `pkexec`, `chage`, `accounts-daemon`) by a single unprivileged process; unexpected access to `/etc/ssh/ssh_host_*` private key files by non-root, non-`sshd` processes; unexpected read access to `/etc/shadow` by non-privileged processes.

Post-exploitation indicators include: SSH host key files accessed outside expected `sshd` startup windows; new `authorised_keys` entries or SSH config modifications; new cron jobs, services, or `setuid` binaries created in atypical paths; `/etc/shadow` or `/etc/passwd` write operations from unexpected processes.

5.2 Sigma Rule — `pidfd_getfd` Abuse Detection

```
title: Linux Kernel ptrace FD Theft via pidfd_getfd (CVE-2026-46333)
id: a4f2b1c9-3e7d-4a8f-b2c5-1d9e0f3a4b5c
status: experimental
description: >
  Detects potential exploitation of CVE-2026-46333 via unprivileged use of
  pidfd_getfd syscall racing a SUID process exit to clone file descriptors.
references:
  - https://blog.qualys.com/vulnerabilities-threat-research/2026/05/20/cve-2026-46333
  - https://nvd.nist.gov/vuln/detail/CVE-2026-46333
author: Lost Boys Cyber
date: 2026-05-28
tags:
  - attack.privilege_escalation
  - attack.t1068
  - attack.credential_access
  - attack.t1552.004
logsource:
  product: linux
```

```

service: auditd
detection:
  selection_syscall:
    type: SYSCALL
    syscall: 438
  filter_root:
    uid: 0
  filter_trusted:
    comm:
      - sshd
      - gdb
      - strace
      - ltrace
  condition: selection_syscall and not (filter_root or filter_trusted)
falsepositives:
  - Legitimate debugging tools running with elevated privileges
  - Custom monitoring agents using pidfd APIs
level: high

```

5.3 Audit / Log Indicators

Event / Source	Relevance	Key Fields to Inspect
auditd SYSCALL type=438	pidfd_getfd invocation by unprivileged process	uid, pid, comm, success, a0-a3
auditd SYSCALL type=434	pidfd_open — obtains PID fd of target process	uid, pid, a0 (target PID)
auditd OPEN on /etc/shadow	Unexpected shadow file read	uid, comm, success, exe
auditd OPEN on /etc/ssh/ssh_host_*	SSH host key file access outside sshd	uid, comm, path, success
Sysmon for Linux Event 1	SUID binary execution in rapid sequence	CommandLine, User, ParentCommandLine
Sysmon for Linux Event 11	File created in /tmp or /dev/shm post-exploit	TargetFilename, Image
/var/log/auth.log	Unexpected root logins or su events following SUID exec chains	timestamp, user, source

5.4 Microsoft Defender for Endpoint (KQL)

```

// CVE-2026-46333 - SSH host key file access from unexpected processes
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath startswith "/etc/ssh/ssh_host"
| where InitiatingProcessFileName !in~ ("sshd", "ssh-keygen", "ssh-
keysign",
    "rsync", "tar", "backup", "clamscan")
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName,
    FolderPath, FileName, ActionType
| order by Timestamp desc

```

```
// CVE-2026-46333 - High-frequency SUID binary execution (race condition
pattern)
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName in~ ("ssh-keysign","pkexec","chage","accounts-
daemon","newgrp")
| where AccountName !in~ ("root","sshd","systemd-logind")
| summarize Count=count() by bin(Timestamp, 1m), DeviceName, AccountName,
FileName
| where Count > 10
| order by Timestamp desc
```

5.5 YARA Rule

```
rule CVE_2026_46333_FDTheft_PoC {
  meta:
    description = "Detects binaries associated with CVE-2026-46333 ssh-
keysign-pwn PoC exploits"
    author      = "Lost Boys Cyber"
    date        = "2026-05-28"
    reference    = "https://blog.qualys.com/vulnerabilities-threat-
research/2026/05/20/cve-2026-46333"
    severity     = "high"

  strings:
    $s1 = "ssh-keysign-pwn" ascii wide
    $s2 = "pidfd_getfd" ascii
    $s3 = "/etc/ssh/ssh_host" ascii
    $s4 = "ptrace_may_access" ascii
    $s5 = "/proc/%d/fd" ascii
    $syscall_pidfd = { B8 B6 01 00 00 }

  condition:
    uint32(0) == 0x464C457F and
    ((2 of ($s1, $s2, $s3, $s4, $s5)) or $syscall_pidfd)
}
```

6. Threat Hunting

Run these hunts across at least 30-90 days of historical telemetry. The exploit is quiet and opportunistic exploitation may have occurred before patching was applied.

6.1 Hunt: Unprivileged pidfd_getfd Activity

Hypothesis: If CVE-2026-46333 was exploited, we will see pidfd_getfd (syscall 438) invoked by a non-root process targeting a SUID binary PID in auditd or EDR telemetry.

Data sources required: auditd SYSCALL events, EDR process telemetry, Linux syslog.

```
# Auditd - search for pidfd_getfd by non-root accounts (last 90 days)
ausearch -sc pidfd_getfd --start 90 days ago | grep -v "uid=0"

# Verify auditd rule is active (add if missing)
```



```
auditctl -a always,exit -F arch=b64 -S 438 -k pidfd_getfd_audit
```

Triage: Identify calling process and user. Cross-reference with SUID binary execution in the same timeframe. Any hit from a non-root, non-debugging-tool process warrants immediate investigation.

6.2 Hunt: SSH Host Key File Access Outside Normal Channels

Hypothesis: If SSH host keys were stolen, we will see access to `/etc/ssh/ssh_host_*` by a process other than `sshd`, `ssh-keygen`, or authorised backup agents.

```
DeviceFileEvents
| where Timestamp > ago(90d)
| where FolderPath has "/etc/ssh/ssh_host"
| where InitiatingProcessFileName !in~ ("sshd", "ssh-keygen", "ssh-
keysign", "rsync", "tar", "backup")
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName,
FolderPath
```

6.3 Hunt: Persistence Mechanisms Post-Exploitation

Hunt for new scheduled tasks, cron jobs, setuid binaries, or `authorized_keys` entries created in the 24-48 hours following any anomalous SUID execution chains detected above. Correlate timestamps against the process anomaly findings.

```
// New cron entries or at jobs
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has_any ("/etc/cron", "/var/spool/cron",
"/.ssh/authorized_keys")
| where ActionType == "FileCreated" or ActionType == "FileModified"
| where InitiatingProcessFileName !in~ ("cron", "crond", "anacron", "sshd")
| project Timestamp, DeviceName, AccountName, FolderPath, FileName,
InitiatingProcessFileName
```

7. MITRE ATT&CK Mapping

Tactic	Technique / Sub-Technique	Relevance to CVE-2026-46333
Privilege Escalation	T1068 — Exploitation for Privilege Escalation	Core exploitation — ptrace race condition achieves root code execution
Credential Access	T1552.004 — Unsecured Credentials: Private Keys	SSH host private key theft via file descriptor cloning
Credential Access	T1003.008 — OS Credential Dumping: /etc/passwd & /etc/shadow	/etc/shadow access to extract password hashes for offline cracking
Defense Evasion	T1548.001 — Abuse Elevation Control Mechanism: Setuid/Setgid	Abuse of SUID binary exit window as the exploitation primitive
Discovery	T1083 — File and Directory Discovery	Locating exploitable SUID binaries on the target system

Lateral Movement	T1021.004 — Remote Services: SSH	Post-exploitation use of stolen SSH host keys to pivot to downstream systems
Persistence	T1098.004 — Account Manipulation: SSH Authorized Keys	Attacker adds SSH keys after root escalation to maintain persistent access
Collection	T1005 — Data from Local System	Exfiltration of SSH keys and shadow file hashes for further attacks

8. Recommended Actions Summary

Priority	Action	Owner	Timeline
P1 — Critical	Apply vendor kernel patch (commit 31e62c2ebbfd)	IT / Patching Team	Immediately
P1 — Critical	Set kernel.yama.ptrace_scope=2 as interim workaround	Sysadmin / Cloud Ops	Within 24 hours
P1 — Critical	Audit and remove unnecessary SUID binaries	Sysadmin	Within 24 hours
P2 — High	Deploy auditd rules monitoring syscall 438 (pidfd_getfd)	SOC / Detection Eng.	Within 48 hours
P2 — High	Deploy MDE KQL detection rules in Sentinel / Defender	SOC / Detection Eng.	Within 48 hours
P2 — High	Run 90-day retrospective threat hunt for SSH key file access	Threat Hunt Team	Within 72 hours
P2 — High	Apply seccomp profile denying pidfd_getfd on container workloads	Cloud / DevSecOps	Within 72 hours
P3 — Medium	Rotate SSH host keys on all Linux systems post-patching	Sysadmin	Within 1 week
P3 — Medium	Patch compliance report — % patched by asset tier	Vuln. Management	Within 1 week
P3 — Medium	Update YARA with confirmed sample	Threat Intel	As samples emerge

	hashes as exploits emerge		
--	------------------------------	--	--

9. References

- [1] Qualys. "CVE-2026-46333: Local Root Privilege Escalation and Credential Disclosure in the Linux Kernel ptrace Path." <https://blog.qualys.com/vulnerabilities-threat-research/2026/05/20/cve-2026-46333>
- [2] NVD. "CVE-2026-46333 Detail." <https://nvd.nist.gov/vuln/detail/CVE-2026-46333>
- [3] Red Hat. "CVE-2026-46333 — Red Hat Customer Portal." <https://access.redhat.com/security/cve/cve-2026-46333>
- [4] Ubuntu Security Team. "CVE-2026-46333." <https://ubuntu.com/security/CVE-2026-46333>
- [5] CloudLinux. "CVE-2026-46333 — Mitigation and Kernel Update on CloudLinux." <https://blog.cloudlinux.com/ptrace-exit-race-cve-2026-46333-mitigation-and-kernel-update>
- [6] Penlilent AI. "ssh-keysign-pwn, The Linux fd theft bug behind CVE-2026-46333." <https://www.penlilent.ai/hackinglabs/ssh-keysign-pwn/>
- [7] Windows News. "CVE-2026-46333 Linux ptrace Fix: What Azure Linux 3.0 IT Teams Must Patch." <https://windowsnews.ai/article/cve-2026-46333-linux-ptrace-fix-what-azure-linux-30-it-teams-must-patch.420047>
- [8] SentinelOne. "CVE-2026-46333: Linux Kernel Privilege Escalation Flaw." <https://www.sentinelone.com/vulnerability-database/cve-2026-46333/>
- [9] MITRE ATT&CK. "T1068 — Exploitation for Privilege Escalation." <https://attack.mitre.org/techniques/T1068/>
- [10] MITRE ATT&CK. "T1552.004 — Unsecured Credentials: Private Keys." <https://attack.mitre.org/techniques/T1552/004/>